Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé

Codjo Fréjus Loïc SANGRONIO

Licence Informatique | Option Sécurité Informatique

24 juin 2026

Encadreur :
Ing. Guy KPEDJO

[OUVERTURE]

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour.

Permettez-nous d'exprimer notre profonde reconnaissance pour votre présence. Ce jour est l'aboutissement de ces années de formation, un moment qui restera gravé dans notre parcours.

Le sujet de notre étude est intitulé : *Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé*.

C'est avec fierté et humilité que nous vous présentons RansomShield — un système conçu de bout en bout pour détecter et contrer les attaques ransomware, de manière contrôlée et traçable, avec une validation humaine à chaque étape décisive.

↪ Voici comment s'articule cette présentation.

Sommaire

1. Introduction Générale
2. Revue de littérature
3. Analyse et Conception
4. Réalisation et Résultats
5. Conclusion et Perspectives

Sommaire
1. Introduction Générale
2. Revue de littérature
3. Analyse et Conception
4. Réalisation et Résultats
5. Conclusion et Perspectives

[SOMMAIRE]

Notre présentation s'articule en cinq parties. Nous partirons du contexte et de la problématique, pour aller vers un état des lieux des solutions existantes, puis la conception et la réalisation. Nous conclurons par les perspectives et terminerons par une démonstration en conditions réelles.

↪ Commençons par le contexte et la problématique.

Introduction Générale

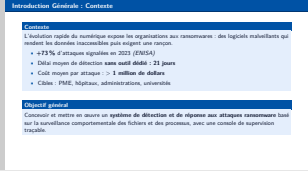
Contexte

L'évolution rapide du numérique expose les organisations aux ransomwares : des logiciels malveillants qui rendent les données inaccessibles puis exigent une rançon.

- **+73 %** d'attaques signalées en 2023 *(ENISA)*
- Délai moyen de détection **sans outil dédié : 21 jours**
- Coût moyen par attaque : $>$ **1 million de dollars**
- Cibles : PME, hôpitaux, administrations, universités

Objectif général

Concevoir et mettre en œuvre un **système de détection et de réponse aux attaques ransomware** basé sur la surveillance comportementale des fichiers et des processus, avec une console de supervision traçable.



[CONTEXTE]

Aujourd'hui, les entreprises, les hôpitaux, les universités fonctionnent grâce à leurs données numériques. Le ransomware — un logiciel malveillant qui rend les données inaccessibles puis exige une rançon — exploite précisément cette dépendance. En 2023, ces attaques ont progressé de 73 % selon l'ENISA, avec un coût moyen de plus d'un million de dollars par incident. Ce qui est grave : sans outil adapté, une attaque passe en moyenne 21 jours sans être détectée.

↪ Ce constat nous amène à la problématique centrale.

Problématique

Constat

Les antivirus classiques détectent les malwares **connus par leur empreinte**. Face aux variantes nouvelles, ils sont aveugles. Sans outil dédié : **21 jours** en moyenne avant détection — les dommages sont souvent irréversibles.

Problème identifié

Aucune solution open-source, **démontrable en conditions réelles**, n'existe pour la détection comportementale multi-plateforme des ransomwares avec contrôle humain.

Défi #1

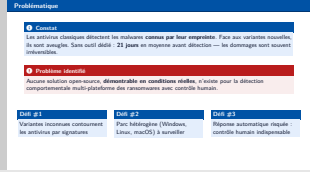
Variantes inconnues contournent les antivirus par signatures

Défi #2

Parc hétérogène (Windows, Linux, macOS) à surveiller

Défi #3

Réponse automatique risquée : contrôle humain indispensable



[PROBLÉMATIQUE]

Les antivirus fonctionnent par reconnaissance d'empreintes : ils connaissent les menaces répertoriées. Mais face à une variante inédite, ils restent aveugles — et pendant ce temps, les données sont chiffrées, les sauvegardes effacées, les dommages deviennent irréversibles.

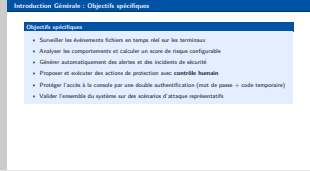
Il n'existe pas de solution libre et démontrable pour détecter ces attaques à partir de leurs comportements, avec un contrôle humain intégré à chaque étape.

Trois défis ont structuré ce travail : les variantes inconnues, la diversité des systèmes à surveiller, et le risque qu'une réponse automatique non validée cause elle-même des dommages.

↪ Ces défis ont défini les six objectifs que voici.

Objectifs spécifiques

- Surveiller les événements fichiers en temps réel sur les terminaux
- Analyser les comportements et calculer un score de risque configurable
- Générer automatiquement des alertes et des incidents de sécurité
- Proposer et exécuter des actions de protection avec **contrôle humain**
- Protéger l'accès à la console par une double authentification (mot de passe + code temporaire)
- Valider l'ensemble du système sur des scénarios d'attaque représentatifs



[OBJECTIFS]

Six objectifs précis ont guidé ce travail : surveiller en temps réel les fichiers sur chaque terminal ; calculer un niveau de risque ; déclencher des alertes automatiquement. Le principe fondateur : chaque action passe par la décision d'un opérateur humain. L'accès est sécurisé par double authentification — mot de passe et code temporaire valide 30 secondes. Et pour valider l'ensemble, des scénarios d'attaque représentatifs ont été définis et exécutés.

↪ Voyons maintenant les fondements théoriques de ce travail.

Revue de littérature

Revue de littérature

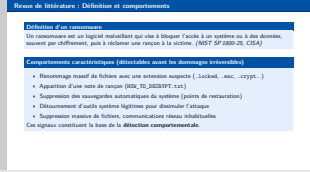
Définition d'un ransomware

Un ransomware est un logiciel malveillant qui vise à bloquer l'accès à un système ou à des données, souvent par chiffrement, puis à réclamer une rançon à la victime. *(NIST SP 1800-25, CISA)*

Comportements caractéristiques (détectables avant les dommages irréversibles)

- Renommage massif de fichiers avec une extension suspecte (`.locked`, `.enc`, `.crypt`...)
- Apparition d'une note de rançon (`HOW_TO_DECRYPT.txt`)
- Suppression des sauvegardes automatiques du système (points de restauration)
- Détournement d'outils système légitimes pour dissimuler l'attaque
- Suppression massive de fichiers, communications réseau inhabituelles

Ces signaux constituent la base de la **détection comportementale**.



[DÉFINITION]

Un ransomware agit toujours selon le même schéma : il renomme vos fichiers avec une extension inhabituelle pour les rendre illisibles, dépose une note de rançon, puis efface les sauvegardes pour rendre toute récupération impossible. Il utilise parfois des outils légitimes pour passer inaperçu.

Ce sont ces comportements observables — ces traces — qui forment la base de notre approche. Surveiller ces actions en temps réel permet de réagir avant que les dommages soient irréversibles.

↪ Mais pourquoi les outils existants ne suffisent-ils pas ?

Revue de littérature : Solutions existantes

Solutions existantes

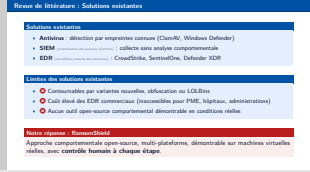
- **Antivirus** : détection par empreintes connues (ClamAV, Windows Defender)
- **SIEM** (centralisation des journaux d'activité) : collecte sans analyse comportementale
- **EDR** (surveillance avancée des terminaux) : CrowdStrike, SentinelOne, Defender XDR

Limites des solutions existantes

- ❌ Contournables par variantes nouvelles, obfuscation ou LOLBins
- ❌ Coût élevé des EDR commerciaux (inaccessibles pour PME, hôpitaux, administrations)
- ❌ Aucun outil open-source comportemental démontrable en conditions réelles

Notre réponse : RansomShield

Approche comportementale open-source, multi-plateforme, démontrable sur machines virtuelles réelles, avec **contrôle humain à chaque étape**.



[SOLUTIONS]

Des solutions existent — voyons pourquoi elles restent insuffisantes.

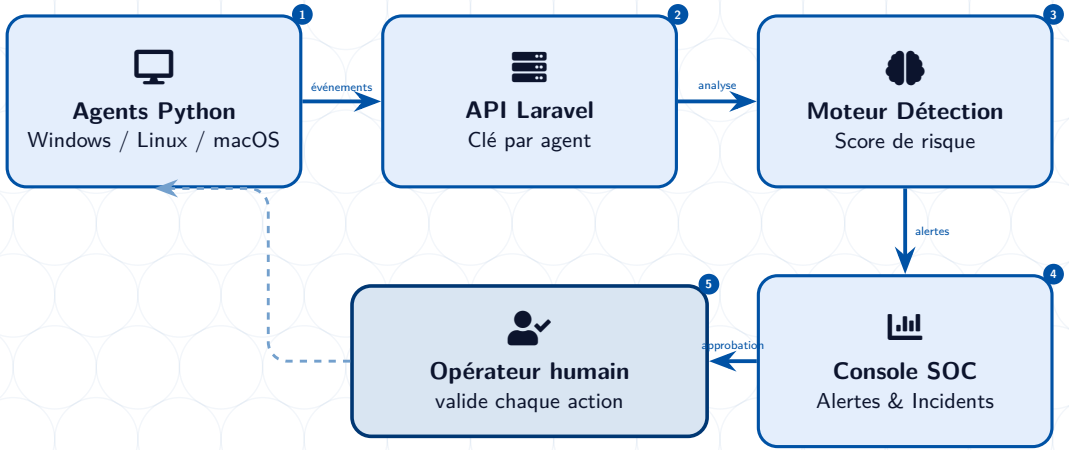
Les antivirus ne reconnaissent que les menaces déjà cataloguées dans leur base de données. Les SIEM — systèmes de centralisation des journaux d'activité — collectent des informations, mais sans chercher activement des comportements suspects. Les EDR — solutions de surveillance avancée des terminaux — sont très efficaces, mais leur coût les rend inaccessibles pour la grande majorité des organisations — PME, hôpitaux, administrations, associations — qui n'ont pas les budgets des grands groupes.

RansomShield occupe cet espace laissé vacant : une solution libre, comportementale, déployable sur n'importe quelle infrastructure, avec un contrôle humain intégré à chaque étape — conçue pour les entreprises et organisations qui veulent se protéger sans dépendre de solutions propriétaires coûteuses.

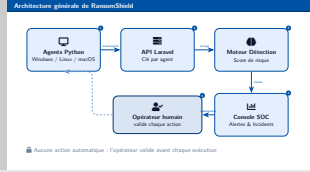
↪ Voyons maintenant comment ce système a été conçu.

Analyse et Conception

Architecture générale de RansomShield



Aucune action automatique : l'opérateur valide avant chaque exécution



[ARCHITECTURE]

Voici l'architecture générale — à lire de gauche à droite.

Un agent sur chaque terminal observe toute activité inhabituelle sur les fichiers. Ces observations sont transmises au serveur central, qui calcule un score de risque. Dès que ce score dépasse le seuil configuré, une alerte est générée et une action de protection est proposée à l'opérateur. C'est lui qui prend la décision finale. Le système n'agit jamais seul.

↪ Voyons de plus près les quatre composants.

Les quatre composants du système

Agent de surveillance

Observe en temps réel les activités fichiers sur chaque terminal. Les événements sont **conservés localement** : rien n'est perdu même en cas de coupure réseau. Démarrage automatique au lancement.

Découverte réseau

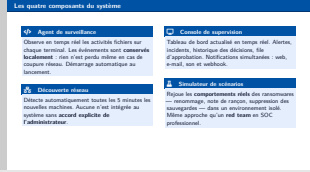
Détecte automatiquement toutes les 5 minutes les nouvelles machines. Aucune n'est intégrée au système sans **accord explicite de l'administrateur**.

Console de supervision

Tableau de bord actualisé en temps réel. Alertes, incidents, historique des décisions, file d'approbation. Notifications simultanées : web, e-mail, son et webhook.

Simulateur de scénarios

Rejoue les **comportements réels** des ransomwares — renommage, note de rançon, suppression des sauvegardes — dans un environnement isolé. Même approche qu'un **red team** en SOC professionnel.



[4 COMPOSANTS]

RansomShield s'articule autour de quatre composants complémentaires.

L'agent : déployé sur chaque machine, il surveille les fichiers en temps réel et stocke tout localement — même hors réseau, rien ne se perd.

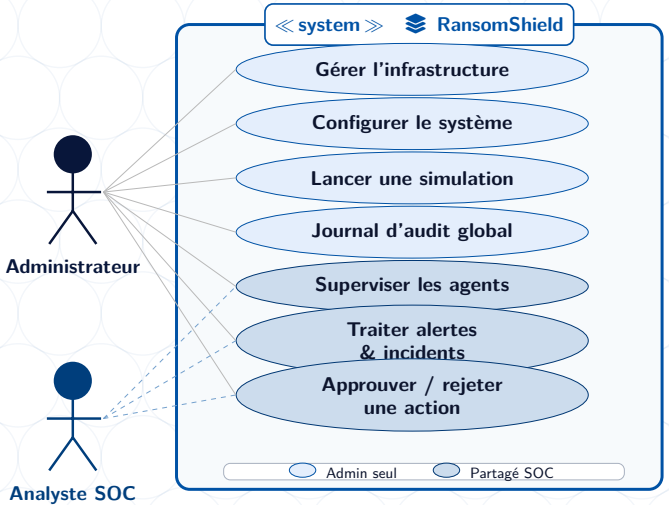
La console : le poste de commandement. L'analyste y voit tout et décide tout — alertes, incidents, file d'approbation, historique complet.

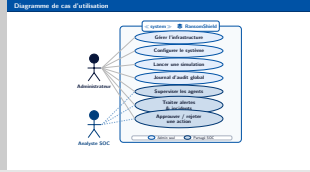
La découverte réseau : elle cartographie l'infrastructure automatiquement et propose les nouvelles machines. Aucune n'est intégrée sans validation explicite de l'administrateur.

Le simulateur : il reproduit les comportements réels des ransomwares dans un environnement isolé. C'est la même approche qu'un red team en SOC professionnel — tester sans risquer les données de production.

↪ Qui sont les acteurs qui interagissent avec ce système ?

Diagramme de cas d'utilisation





[USE CASE]

Ce diagramme reflète la répartition exacte des droits telle qu'elle est codée dans le système.

L'administrateur contrôle l'intégralité : il gère l'infrastructure — réseaux et enrôlement des agents —, configure les règles de détection, lance les simulations et consulte le journal d'audit complet du système.

L'analyste SOC opère sur les événements au quotidien : il supervise les agents en leur envoyant des commandes opérationnelles, traite les alertes et incidents, et approuve ou rejette chaque action de protection avant exécution.

La ligne de partage est nette : l'analyste ne peut ni modifier la configuration, ni consulter le journal d'audit global, ni lancer de simulation.

↪ Passons maintenant à la réalisation concrète.

Réalisation et Résultats

Réalisation et Résultats

Choix techniques

Backend & Base de données

- **Laravel 11** / PHP 8.3
- **MySQL 8.0** (Eloquent ORM)
- API REST sécurisée (clé per-agent)

Frontend

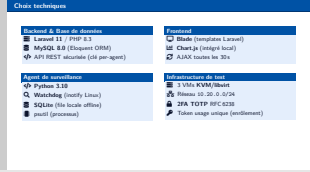
- **Blade** (templates Laravel)
- **Chart.js** (intégré local)
- AJAX toutes les 30 s

Agent de surveillance

- **Python 3.10**
- **Watchdog** (inotify Linux)
- **SQLite** (file locale offline)
- psutil (processus)

Infrastructure de test

- 3 VMs **KVM/libvirt**
- Réseau `10.20.0.0/24`
- **2FA TOTP** RFC 6238
- Token usage unique (enrôlement)



[CHOIX TECHNIQUES]

Les choix techniques ont été guidés par trois critères : portabilité multi-OS, facilité de déploiement, et démontrable sans infrastructure coûteuse.

Le serveur et la console sont développés avec Laravel. L'agent de surveillance est en Python, portable sur Windows, Linux et macOS. Les tests ont été conduits sur trois machines virtuelles en réseau isolé. L'accès à la console est protégé par double authentification : mot de passe puis code temporaire valide 30 secondes.

↪ Voyons concrètement comment l'agent et le moteur fonctionnent.

Agent Python et moteur de détection

Fonctionnement de l'agent

1. Démarrage et configuration automatique
2. Enrôlement sécurisé (jeton à usage unique)
3. Surveillance en temps réel des dossiers
4. Événements conservés localement
5. Transmission sécurisée au serveur central
6. Signal de vie toutes les **30 secondes**

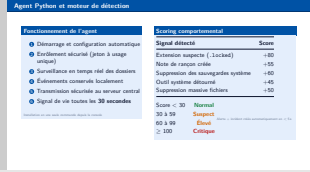
Installation en une seule commande depuis la console

Scoring comportemental

Signal détecté	Score
Extension suspecte (`.locked`)	+80
Note de rançon créée	+55
Suppression des sauvegardes système	+60
Outil système détourné	+45
Suppression massive fichiers	+50

Score < 30	**Normal**
30 à 59	**Suspect**
60 à 99	**Élevé**
≥ 100	**Critique**

Alerte + incident créés automatiquement en < 5 s



[AGENT & MOTEUR DE DÉTECTION]

L'agent démarre, est reconnu par le serveur grâce à un jeton sécurisé, surveille les dossiers et envoie un signal de vie toutes les 30 secondes.

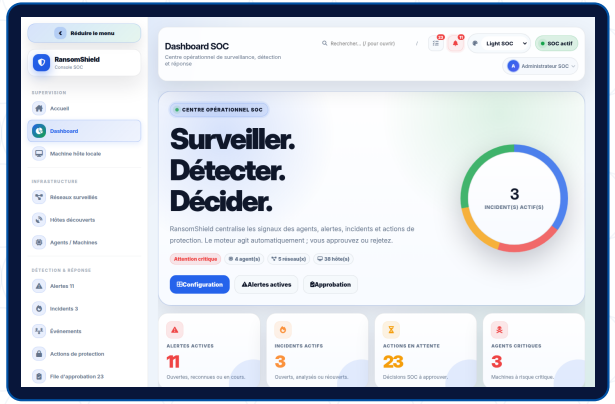
Pour le moteur de scoring : un fichier renommé `.locked` ajoute 80 points au score de risque. Une note de rançon dans le même dossier en ajoute 55. Le score atteint 135 — au-dessus du seuil critique de 100. En moins de cinq secondes, une alerte est générée et un incident est ouvert dans la console, en attente de la décision de l'opérateur.

↪ Côté analyste, voici ce que la console SOC offre.

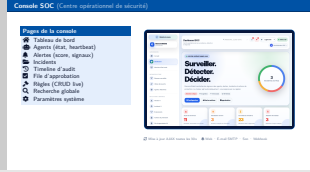
Console SOC (Centre opérationnel de sécurité)

Pages de la console

- Tableau de bord
- Agents (état, heartbeat)
- Alertes (score, signaux)
- Incidents
- Timeline d'audit
- File d'approbation
- Règles (CRUD live)
- Recherche globale
- Paramètres système



Mise à jour AJAX toutes les 30 s · Web · E-mail SMTP · Son · Webhook



[CONSOLE SOC]

Venons-en maintenant à la console SOC — l'interface que l'opérateur utilise au quotidien pour surveiller, réagir et rendre des comptes.

La console regroupe vingt-trois pages en quatre sections : supervision, infrastructure, détection et réponse, et configuration.

Ce qui est fondamental dans RansomShield, c'est que chaque action proposée par le système passe obligatoirement par la file d'approbation. L'analyste l'approuve ou la rejette explicitement. Aucune action ne s'exécute en silence. Ce principe est non négociable.

Dès qu'une alerte est levée, l'opérateur est notifié simultanément par quatre canaux — sur l'interface web, par e-mail, par signal sonore et par webhook — pour s'assurer qu'aucune alerte ne passe inaperçue, quelle que soit sa situation.

↪ Qu'est-ce que les tests ont donné ?

Tests de validation et résultats

5 scénarios d'attaque testés

Scénario	Évts	Résultat
Chiffrement basique	7	✓
Kill chain complète	22	✓
Chiffrement massif	18	✓
Exfiltration données	8	✓
LOLBins suspects	5	✓

3 VMs KVM |

réseau 10.20.0.0/24

Résultats obtenus

- ✓ Détection en < **5 secondes** (tous scénarios)
- ✓ Aucun événement perdu (file SQLite)
- ✓ Pipeline complet validé bout en bout
- ✓ Rollback isolation réseau fonctionnel
- ✓ 2FA TOTP et API sécurisée (per-agent)

Perspective d'évolution

- Extension Windows/macOS
- Chiffrement TLS en production
- Moteur ML pour anomalies inconnues

[TESTS ET VALIDATION]

Cinq scénarios d'attaque ont été définis, du chiffrement simple à la chaîne complète en 22 événements, exécutés sur trois machines virtuelles en réseau isolé — sans jamais déployer de malware réel. Pour chaque scénario, trois indicateurs ont été mesurés : délai de détection, intégrité des données, et complétude de la chaîne jusqu'à la décision de l'opérateur.

Les résultats sont constants : cinq scénarios exécutés, cinq détectés en moins de cinq secondes, zéro événement perdu.

↪ Place maintenant à la démonstration live.

Démonstration Live

[DÉMONSTRATION LIVE]

Suivre le guide de démonstration.

Checklist rapide :

1. Console SOC ouverte : 3 agents en ligne
2. SSH sur `rs-client-1` : renommage `.locked` + note de rançon
3. Revenir sur la console : alerte critique apparue en moins de 5 secondes
4. File d'approbation : approuver l'action, montrer le rollback
5. Timeline : tout est horodaté
6. Simulation kill chain complète : 22 événements

↪ Revenir à la présentation pour conclure.

Conclusion et Perspectives

Conclusion et Perspectives

Conclusion et Perspectives

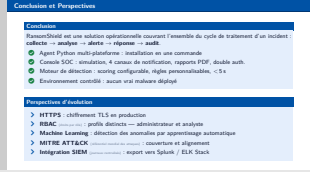
Conclusion

RansomShield est une solution opérationnelle couvrant l'ensemble du cycle de traitement d'un incident : **collecte** → **analyse** → **alerte** → **réponse** → **audit**.

- ✔ Agent Python multi-plateforme : installation en une commande
- ✔ Console SOC : simulation, 4 canaux de notification, rapports PDF, double auth.
- ✔ Moteur de détection : scoring configurable, règles personnalisables, $< 5\,\mathrm{s}$
- ✔ Environnement contrôlé : aucun vrai malware déployé

Perspectives d'évolution

- **HTTPS** : chiffrement TLS en production
- **RBAC** (droits par rôle) : profils distincts — administrateur et analyste
- **Machine Learning** : détection des anomalies par apprentissage automatique
- **MITRE ATT&CK** (référentiel mondial des attaques) : couverture et alignement
- **Intégration SIEM** (journaux centralisés) : export vers Splunk / ELK Stack



[CONCLUSION]

RansomShield couvre l'intégralité du cycle de traitement d'un incident : détection sur le terminal, analyse comportementale, alerte, décision de l'opérateur, archivage complet. Il est opérationnel, démontrable, construit sans malware réel.

Nous n'avons pas la prétention d'avoir épuisé le sujet : chaque remarque du jury est pour nous une opportunité de progresser et de mieux faire.

Les perspectives sont tracées : sécuriser les communications pour la production, affiner les rôles, et doter le moteur d'un apprentissage automatique pour reconnaître les anomalies avec plus de précision.

↪ Nous restons à votre disposition pour vos questions.

Merci pour votre attention

[MERCI — MOT DE CLÔTURE]

Dans un monde où les systèmes automatisent nos décisions, RansomShield rappelle une conviction simple : la machine peut détecter, mais c'est l'humain qui décide. Ce n'est pas une contrainte technique — c'est un choix éthique.

Merci pour votre aimable attention et pour le temps accordé à ce travail.

[POINTS DE RÉPONSE AU JURY]

- **Python vs C/Go :** Watchdog exploite inotify nativement — CPU minimal, portable Linux/Windows/macOS sans recompilation.
- **Fausses alertes :** Seuils configurables. L'analyste valide ou rejette avant toute action — le système ne peut pas agir seul.
- **Absence de HTTPS :** LAN contrôlé pour ce projet. Chiffrement TLS = première perspective pour la production.
- **Différence avec un antivirus :** L'antivirus reconnaît les empreintes. RansomShield observe le comportement — variantes inédites couvertes.
- **Tests Windows :** Limite assumée — Linux uniquement. Extension à Windows = première perspective d'évolution.